🛡️ 令和元年秋 应用情報 午後問1【情報セキュリティ】 小南解题 🚀

一、 整体背景梳理 🚨🏢

- 🏢 **企业背景与网络现状：**
  - **P 社概况**：从事工厂控制设备设计、开发与销售的制造企业（员工约 50 人）。
  - **终端与邮件配置**：员工每人配发 1 台 PC，有线接入社内 LAN 并分配固定 IP。收信使用 POP3（开启身份认证），发信使用 SMTP（**未开启认证**）。
  - **边界策略**：防火墙（FW）仅允许 PC 通过 **HTTP 和 HTTPS** 访问外网，其余出站流量全部阻断。
- 🎣 **突发安全事件（靶向钓鱼邮件攻击）：**
  - **攻击手法**：员工收到冒充总务部长 X 的邮件，诱导解压并运行带密码的附件（所谓“情报收集工具”）。
  - **中招与惊险拦截**：设计部 Z 员工打开运行了附件。恶意进程试图通过 **SSH** 连接外部服务器，但因 FW 禁止 SSH 出站而通信失败。
  - **应急排查**：IT 担当 Y 立即拔网线隔离被疑 PC，委托外包 Q 社分析日志，确认其他 PC 未出现异常外联。
- 🛡️ **纵深防御升级（不改变社内 LAN 拓扑前提下）：**
  - **入口对策（入口对策）**：邮件服务器增加杀毒与发信域名认证（SPF）拦截伪造邮件；引入 URL 过滤防范水坑攻击。
  - **出口对策（出口对策）**：SMTP 发信增加用户认证；禁止 PC 直连外网，强制经由 DMZ 新设的 Proxy 服务器（带用户认证）上网；委托 Q 社监控 FW 与 Proxy 日志。

二、 逐题深度解析 🔍📝

設問1：靶向邮件应急响应与初期排查 🚨🔌

(1) 下划线①：Y 将被疑 PC 从网络断开的目的是什么？（20字以内）

- 🎯 **参考答案：**

> **社内の他の機器と通信させないため**（16字）
>
> *(中文释义：为了不让其与社内的其他设备进行通信)*

- 💡 **逻辑拆解：**
  - 🔌 **黄金第一法则**：一旦发现终端疑似感染恶意软件，首要动作是物理拔除网线或关闭 Wi-Fi 隔离网络。
  - 🛑 **阻断目标**：防止恶意软件利用内网横向移动（感染其他电脑）或对外发起恶意连接，将被害控制在单机范围内。

(2) 下划线②：可疑进程与外部特定服务器通信失败的原因？（20字以内）

- 🎯 **参考答案：**

> **FWでアクセスが許可されていないから**（18字）
>
> *(中文释义：因为防火墙（FW）未允许该访问)*

- 💡 **逻辑拆解：**
  - 🚧 **端口与协议限制**：恶意软件试图使用 **SSH** 协议外联。
  - 🛡️ **现行策略立功**：P 社的 FW 规则明确规定“仅允许 HTTP 和 HTTPS 出站，其余全部遮断”，因此 SSH 外联请求直接被 FW 拦截。

(3) 填空 a：Q 社通过分析图1 中哪个设备的日志，确认了没有其他 PC 感染？

- 🎯 **参考答案：**
  - **a**：**FW**
- 💡 **逻辑拆解：**
  - 🔍 **溯源依据**：如果其他员工也中招运行了同一恶意软件，同样会向外发起 SSH 连接并被 FW 阻断记录。
  - 📌 **固定 IP 优势**：P 社社内 LAN 均分配**固定 IP 地址**，因此直接查看 **FW** 的拦截日志就能精准排查出是否有其他源 IP 发起过异常 SSH 请求。

設問2：靶向攻击技术对策与员工规范 🛡️🔐

(1) 填空 b：表2 中邮件服务器引入的发信域名认证技术？（四选一）

- 🎯 **参考答案： エ（SPF）**
- 💡 **逻辑拆解：**
  - **エ（SPF / Sender Policy Framework）** ✅：受信侧邮件服务器通过查询发信方 DNS 发布的 SPF 记录，比对发信源 IP 是否合法，从而完成**域名级别**的真实性校验。
  - **ア（OP25B）** ❌：ISP 阻断动态 IP 直接对外连接 25 端口发送垃圾邮件的技术。
  - **イ（PGP） & ウ（S/MIME）** ❌：均基于公钥密码体系，用于端到端的邮件加密与数字签名（属于**客户端/个人级别**认证，而非域名认证）。

(2) 填空 c & d：SPF 检测目标与恶意软件高危通信协议？（各20字以内）

- 🎯 **参考答案：**
  - **c：送信元メールアドレスのなりすまし**（16字）

    (中文释义：发件人邮箱地址的冒充/伪造)
  - **d：HTTP又はHTTPS**（11字）
- 💡 **逻辑拆解：**
  - **填空 c（防伪造）**：钓鱼邮件常篡改邮件头伪装成公司内部高管，SPF 能够识别域名与发信服务器不匹配，从而精准抓出**发件人邮箱冒充（なりすまし）**。
  - **填空 d（防穿透）**：本次事件幸亏恶意软件用了 SSH 才被 FW 挡住；若恶意软件使用 FW 默认放行的 **HTTP 或 HTTPS** 协议与控制端通信，就会直接穿透防火墙导致泄密。

(3) 下划线③：水坑攻击（水飲み場攻撃）中，恶意软件最可能被提前植入哪里？（四选一）

- 🎯 **参考答案： ア（P社従業員がよく利用するサイト）**
- 💡 **逻辑拆解：**
  - 🐊 **攻击隐喻**："水坑攻击"就像鳄鱼潜伏在动物每天必去喝水的水坑旁——攻击者会事先攻陷目标公司员工**经常访问的合法网站**并植入挂马代码，坐等员工日常浏览时自动下载恶意软件。

(4) 下划线④：引入带认证的 Proxy 和 URL 过滤后，恶意软件具备什么功能仍可能绕过防御连上 C&C 服务器？（四选一）

- 🎯 **参考答案： エ（プロキシサーバの利用者認証情報を窃取する機能）**
- 💡 **逻辑拆解：**
  - 🔐 **出口防线机制**：改造后所有外网访问必须经过 Proxy 服务器并输入用户 ID 和密码认证（出口对策）。
  - 🕵️ **绕过原理**：部分高阶恶意软件能够读取本机浏览器或系统缓存中的**代理服务器用户认证信息**。一旦窃取凭证，恶意软件就能冒充合法员工穿过 Proxy 认证，连接尚未被黑名单收录的 C&C 服务器。

(5) 下划线⑤：员工发现可疑邮件时，不解压、不执行之外最恰当的行动？（四选一）

- 🎯 **参考答案： イ（不審なメールが届いたことをP社の情報システム担当に連絡する）**
- 💡 **逻辑拆解：**
  - 📢 **标准处置流程**：收到可疑邮件时，切忌保存在本地（防止日后遗忘误点），更不能点击邮件正文里的链接去核实真伪。正确做法是**立即向信息系统担当报告**，以便 IT 部门全员预警与溯源拦截。

三、 核心考点速查表 📌⚡

考察维度 📐	💡 考点核心	⚙️ 原理与解题要诀
🚨 **应急隔离处置**	**断网隔离 & FW 日志排查**	发现感染第一时间断开网络防横向扩散；固定 IP 环境下通过分析 FW 拦截日志排查其他受感染终端。
📧 **邮件安全认证**	**SPF (送信ドメイン認証)**	校验发信源 IP 与 DNS 的 SPF 记录是否一致，专门识别**发件人邮箱冒充（なりすまし）**。
🐊 **网页挂马攻击**	**水飲み場攻撃 (水坑攻击)**	入侵目标组织员工**经常访问的网站**植入恶意代码，配合 URL 过滤功能可有效拦截。
🚪 **出口对策与绕过**	**認証付き Proxy & 認証窃取**	强制经由带身份认证的 Proxy 上网可阻断恶意软件外联；但若恶意软件具备**窃取代理认证信息**的功能仍可能突破防线。
👩‍💻 **人员安全规范**	**可疑邮件报告机制**	不回复、不解压、不留存、不点链接，第一时间**向情报系统担当汇报**。